BTS CIEL-IR · PROGRAMMATION WEB

<?php

Programmation PHP

Écrire des pages dynamiques, traiter des formulaires, interroger MariaDB — avec les bons réflexes de sécurité.

Pages dynamiques | Formulaires | Sessions & cookies | PDO / MariaDB | Sécurité

01 · PRINCIPE

Comment PHP fonctionne

Navigateur

Envoie une requête HTTP (GET ou POST), puis affiche le HTML reçu.

Serveur web + PHP

Apache exécute le script .php, interroge la base si besoin et génère du HTML.

MariaDB

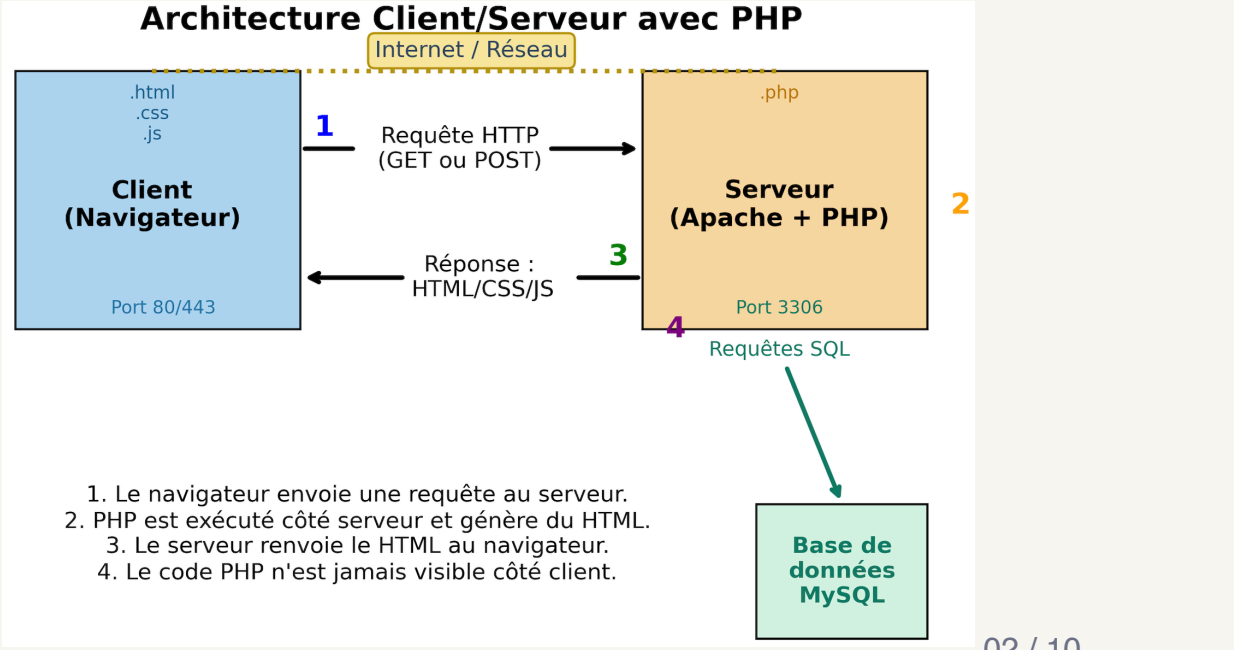
Stocke les données et répond aux requêtes SQL du script.

> Le navigateur ne voit **jamais** le code PHP : seulement le HTML généré.

> Chaque requête est **indépendante** : à la fin du script, les variables PHP sont perdues.

```
# En local avec XAMPP (Apache + MariaDB)
htdocs/cours_TP_PHP/index.php
→ http://localhost/cours_TP_PHP/

# Sans Apache : serveur intégré de PHP
php -S localhost:8000
```



Variables, types et affichage

```php
<?php
$nom = "Carnus"; // $ + nom, sensible à la casse
$age = 20;
const TVA = 0.2; // constante : pas de $

echo "$nom a $age ans"; // Carnus a 20 ans
echo 'Bonjour $nom'; // Bonjour $nom
echo "<h2>" . $nom . "</h2>"; // concaténation

var_dump($age); // int(20)
var_dump("1" == "01"); // bool(true) !
var_dump("1" === "01"); // bool(false)
```

Balises

Code entre <?php et ?> ; on omet ?> dans un fichier 100 % PHP. Raccourci : <?= $x ?>

Guillemets

Doubles : les variables sont remplacées. Simples : texte brut.

Comparer

=== et !== comparent la valeur **et** le type : à préférer à ==.

Déboguer

var_dump() affiche le type et la structure ; l'entourer de <pre> dans le navigateur.

Conditions, boucles et fonctions

Conditions et boucles

```php
$libelle = match ($jour) { // PHP 8
  6, 7 => "Week-end",
  default => "Semaine",
};

for ($i = 0; $i < 5; $i++) { … }

foreach ($ages as $nom => $age) {
  echo "$nom a $age ans<br>";
}
```

match renvoie une valeur et compare avec ===. Dans un switch, ne pas oublier break.

Fonctions typées

```php
function ttc(float $ht, float $tva = 0.2): float {
  return $ht * (1 + $tva);
}
echo ttc(100); // 120

// & : passage par référence
function inc(int &$x): void { $x++; }
$n = 5; inc($n); // $n vaut 6
```

Les variables d'une fonction sont **locales** : passer les valeurs en paramètres plutôt qu'utiliser global.

Tableaux et superglobales

Trois formes de tableaux

```php
// indexé
$marques = ["HP", "Apple", "Dell"];
$marques[] = "Lenovo"; // ajout
echo count($marques); // 4

// associatif
$ages = ["Charles" => 19, "Carnus" => 20];
echo $ages["Carnus"]; // 20

// à deux dimensions (TP1)
$contacts = [["nom" => "Charles"]];
echo $contacts[0]["nom"]; // Charles
```

Les superglobales

Variable	Contient
$_GET	Paramètres de l'URL : ?nom=Dupont
$_POST	Champs d'un formulaire envoyé en POST
$_SERVER	Requête et serveur (REQUEST_METHOD…)
$_SESSION	Données de session, côté serveur
$_COOKIE	Cookies renvoyés par le navigateur
$_FILES	Fichiers téléversés

Une clé peut manquer : lire avec `$_GET["nom"] ?? ""` ou tester avec `isset()`.

Traiter un formulaire en cinq temps

1 **Initialiser**

Les erreurs à [] et les champs à "" pour réafficher le formulaire.

2 **Tester la méthode**

POST pour ce qui modifie des données, GET pour une recherche partageable.

3 **Valider côté serveur**

trim(), filter_var(), preg_match() : required et pattern se contournent.

4 **Cumuler les erreurs**

Un message par champ ; traitement seulement si la liste est vide.

5 **Réafficher, échappé**

htmlspecialchars() contre le XSS ; redirection après un succès.

```
$erreurs = [];
$nom = "";

if ($_SERVER["REQUEST_METHOD"] === "POST") {
  $nom = trim($_POST["nom"] ?? "");
  $email = trim($_POST["email"] ?? "");

  if ($nom === "") {
    $erreurs[] = "Le nom est obligatoire.";
  }
  if (!filter_var($email, FILTER_VALIDATE_EMAIL)) {
    $erreurs[] = "Email invalide.";
  }
  if (empty($erreurs)) { /* traiter */ }
}
```

Garder un utilisateur connecté

HTTP est sans mémoire : la session relie les requêtes d'un même visiteur.

1. **session_start()**
   Crée ou reprend la session ; envoie le cookie PHPSESSID.
2. **$_SESSION**
   Les données restent stockées sur le serveur.
3. **Requêtes suivantes**
   Le navigateur renvoie l'identifiant ; PHP retrouve les données.

> session_start(), header() et setcookie() : **avant tout affichage**, sinon « headers already sent ».

```php
// login.php — identifiants vérifiés
session_start();
session_regenerate_id(true);
$_SESSION["utilisateur"] = $identifiant;
header("Location: compte.php");
exit;

// compte.php — page protégée
session_start();
if (!isset($_SESSION["utilisateur"])) {
  header("Location: login.php");
  exit; // toujours après header()
}
```

Approfondissement : cours **Cookies & Sessions** (déconnexion, « se souvenir de moi »).

Interroger MariaDB avec PDO

```php
// db.php — root sans mot de passe : configuration XAMPP, en local uniquement
$pdo = new PDO("mysql:host=localhost;dbname=boutique;charset=utf8mb4", "root", "", [
  PDO::ATTR_ERRMODE => PDO::ERRMODE_EXCEPTION,
  PDO::ATTR_DEFAULT_FETCH_MODE => PDO::FETCH_ASSOC,
]);
```

À ne jamais faire : injection SQL

```php
$sql = "SELECT * FROM utilisateurs
  WHERE identifiant = '" . $_POST["id"] . "'";

// saisie : ' OR '1'='1
// → la condition est toujours vraie
```

Requête préparée : la saisie reste une donnée

```php
$stmt = $pdo->prepare("SELECT id, mot_de_passe
  FROM utilisateurs WHERE identifiant = :id");
$stmt->execute(["id" => $identifiant]);
$utilisateur = $stmt->fetch(); // ou false
```

Sept réflexes à prendre

Risque	Parade	En PHP
Données non fiables	Valider côté serveur	trim(), filter_var(), preg_match()
XSS	Échapper à l'affichage	htmlspecialchars($x, ENT_QUOTES, "UTF-8")
Injection SQL	Ne jamais concaténer une saisie	Requêtes préparées PDO
Mots de passe volés	Ne jamais stocker en clair	password_hash() / password_verify()
Fixation de session	Nouvel identifiant à la connexion	session_regenerate_id(true)
CSRF	Jeton secret dans chaque formulaire	random_bytes() + hash_equals()
Écoute du réseau	Chiffrer les échanges	HTTPS ; display_errors = Off en production

À la connexion, un message générique : « Identifiant ou mot de passe incorrect ». Jamais md5() ni sha1() pour un mot de passe.

Erreurs fréquentes et méthode

Symptôme	Cause probable	Solution
Le code PHP s'affiche tel quel	Fichier ouvert en file://	Passer par http://localhost/…
Page blanche	Erreur fatale masquée	display_errors et E_ALL en dev
Undefined array key "nom"	Champ jamais envoyé	Initialiser, utiliser ??
headers already sent	Affichage avant header()	Ces appels tout en haut
SQLSTATE [2002] Connection refused	MariaDB arrêté	Lancer MySQL dans XAMPP

1. Lire tout le message (fichier, ligne)
2. var_dump() entre <pre>
3. Isoler l'instruction fautive
4. Une modification à la fois